What a Token Does Not Hide: Leakage Quantification and Disclosure Budgets for LLM Gateways over Corporate Ledgers

Eunice Lee Sophia Shim Caleb Lee

J1729Labs

director@j1729labs.online

Abstract

Gateways that place a tokenizing layer between an enterprise database and a hosted language model are now a standard privacy control, and are usually justified by analogy to pseudonymization. We ask, and answer by measurement, what that analogy is worth when the records describe *corporations* rather than natural persons.

Korean business data is the sharpest case. Its quasi-identifier space holds more cells than there are publicly enumerable corporations, so uniqueness is forced by arithmetic before any attack begins, and every coordinate of that space is published by statute rather than acquired by an adversary. On a synthetic 4,000-account ledger calibrated to published Korean aggregates, two public attributes single out 41.4% of accounts inside a 40,000-firm directory and four single out 91.5%.

We measure three attacks—attribute combination, cross-session token linkage and differential inference—and find that their leakage does not compose additively. The disclosed columns alone re-identify 7.3% of the ledger; exact aggregates alone and the co-occurrence graph alone re-identify none of it; the three together reach 9.8%. The dominant variable is not the tokenization scheme but which columns the gateway lets through beside the token: the same pipeline re-identifies 1.2% of the ledger under a token-only profile and 86.3% under the profile an analyst asks for unprompted.

We then price the aggregate channel. Exact aggregates over caller-chosen sets admit no finite ε, and a minimum aggregate size k does not repair this, because isolability equals ledger uniqueness and is independent of k. Randomization prices badly against heavy-tailed corporate amounts: the noise an analyst tolerates buys $\varepsilon \approx 111$ per query. We give a four-component disclosure budget and instantiate it for four product configurations.

Keywords: leakage quantification; re-identification; tokenization; differential privacy; database reconstruction; language-model gateways; disclosure budget

1 Introduction

A recognizable architecture has settled into enterprise deployments of hosted language models. The model is not trusted with the database. Between the two sits a gateway: it resolves the model's tool calls against the enterprise store, replaces every business identifier with a token, suppresses per-row figures, and returns aggregates. Vendors describe the result as pseudonymization, and buyers—particularly in regulated sectors—accept the description.

The question this paper asks is the one a procurement officer eventually asks out loud: *what exactly is the difference between this and pseudonymization, in numbers?* It is a fair question, and the honest answer turns out to depend almost entirely on a design choice that vendors rarely document: which columns the gateway lets through in plaintext beside the token.

We answer it in the setting where the answer matters most and is least studied. Almost the entire re-identification literature concerns natural persons. Its canonical results—Sweeney's finding that 87% of the US population is unique on ZIP code, date of birth and sex [24], the Netflix and social-graph de-anonymizations [19, 20], the credit-card metadata results [7]—all concern individuals, and all rest on auxiliary knowledge that an adversary must go out and acquire.

Corporate records invert both premises. There are fewer corporations than people, their descriptive attributes are far more finely coded, and—decisively— those attributes are *published by statute*. In Korea, a firm's industry code, registered address, revenue band, headcount band, founding year and listing status are all recoverable from the corporate registry and from periodic reports filed to the national disclosure system. An adversary does not need to acquire auxiliary knowledge about corporations. It is handed to them, in a searchable archive, by law.

This paper contributes five things, each of which is a measurement rather than a design.

A corporate re-identification baseline. Section 5 establishes what the person-oriented literature has no counterpart for: how distinctive a corporation is in its own published coordinates. On a synthetic Korean B2B ledger calibrated to published marginals, two public attributes uniquely identify 41.4% of accounts and four identify 91.5%. The effect is structural rather than a property of our generator. The industry×locality space has 273,884 cells against roughly 4×10^4 publicly enumerable firms, so 75.3% of occupied cells hold a single firm. No tokenization scheme changes that ratio, because it is a property of the classification the state chose, not of the database.

A measured non-additivity result. Section 6 decomposes the gateway's leakage into the four components of the companion threat model [18] and measures all seven non-empty combinations of the three that matter here. The disclosed columns alone re-identify 7.3% of the ledger; exact aggregates alone and cross-session co-occurrence alone re-identify nobody at all; together they re-identify 9.8% at 63% precision, or 18.3% if the adversary will accept 32%. What makes this more than an arithmetic curiosity is that the mechanism is specific and reproducible: attribute uniqueness supplies the anchors an unanchored graph attack lacks, exact aggregates invert into continuous quasi-identifiers that sharpen those anchors, and the co-occurrence graph then propagates them into rows that are not distinctive on their own. A budget that prices the components separately misses all of this.

The disclosure profile as the dominant variable. Section 6.5 holds the tokenization scheme, the workload and the adversary fixed and varies only which columns accompany the token. Re-identification moves from 1.2% to 86.3% of the ledger—a factor of seventy—as the profile moves from token-only to what an analyst asks for when nobody says no. Set against this, the control vendors most often advertise barely registers: re-randomizing tokens every session moves re-identification from 9.8% to 7.9% and destroys 100% of cross-session analysis. The operator is optimizing the wrong knob.

Isolability is independent of k. Section 7 proves and then measures that a minimum aggregate size does not prevent differential isolation. When the filter language can express set difference, a record is isolable in two queries precisely when it is unique within the ledger, and we observe the same isolability at every k from 1 to 100. The control that does work is a restriction on the predicate language rather than on the answer size: conjunction-only filters at $k \geq 5$ drop isolability from 70.2% to 0.3%. This relocates the defence from the database to the tool schema, which is where an LLM gateway can actually enforce it.

An honest price for the aggregate channel. Section 9 gives a four-component disclosure budget whose components are computable from logs, shows that the exact-aggregate mode admits no finite ε, and prices the randomized alternative against the heavy tail of corporate amounts. At the noise level an analyst tolerates, $\varepsilon \approx 111$ per query and 1.1×10^5 over a thousand-query epoch; buying $\varepsilon = 1$ costs a median answer error of 867%. We tabulate four product configurations against their measured budgets, which turns a marketing question into a specification decision that has to be made rather than deferred.

What this paper is not. We do not claim the measured percentages transfer to any particular deployment. The corpus is synthetic; we say exactly what is calibrated and what is invented in Section 4, and we report the one workload parameter we cannot estimate without customer logs as a sensitivity curve rather than a point value. We also do not claim the attacks are optimal. Every attack here is a lower bound, and we flag the places where a stronger adversary is obviously available.

2 Background and related work

Leakage-based security definitions. The habit of stating what a system leaks, rather than asserting that it leaks nothing, comes from searchable and structured encryption. Curtmola et al. [5] introduced adaptive security relative to a leakage function; Chase and Kamara [4] generalized it to structured encryption with controlled disclosure. We adopt that discipline: Section 3 states the gateway's leakage components and the rest of the paper measures them.

Leakage-abuse attacks. The complementary tradition shows that declared leakage is rarely benign. Naveed, Kamara and Wright [21] recovered plaintext from property-preserving encrypted databases using public auxiliary data; Cash et al. [3] formalized leakage-abuse attacks on searchable encryption; Grubbs et al. [15] extended this to order-revealing encryption; Kellaris et al. [16] gave generic reconstruction attacks from access-pattern and communication-volume leakage. The structure of our Section 6 is deliberately the same: take the declared leakage, add public auxiliary data, and measure.

Re-identification. Sweeney's uniqueness analysis [24] and k-anonymity [25] established the quasi-identifier framing we borrow. Narayanan and Shmatikov [19, 20] introduced the seeded-propagation graph de-anonymization our token-linkage attack adapts. De Montjoye et al. [6, 7] showed that sparse behavioural traces are uniquely identifying; Rocher et al. [22] addressed

re-identification from incomplete datasets. All of this concerns natural persons. We are not aware of a systematic corporate analogue, which is the gap Section 5 fills.

Reconstruction and differential privacy. Dinur and Nissim [10] showed that answering too many queries too accurately permits database reconstruction; the result motivated differential privacy [11, 12], and was made concrete at scale by the US Census reconstruction exercise [13]. The older statistical-database literature on trackers [9, 1] is the direct ancestor of our isolation attack, and it already knew that minimum query-set sizes are defeated by differencing. Part of our contribution is showing that a control the 1970s discarded has been reintroduced, unexamined, into LLM gateway products.

Privacy for language-model systems. Work here has concentrated on the model: training-data extraction [2], probing for memorized personal data [17], inference of personal attributes from text [23], and private fine-tuning [26]. A second line addresses the tool layer, where indirect prompt injection [14] and agent benchmarks [8] treat the model as an untrusted planner. Our setting sits between the two: the model host is an *honest* recipient of tool results that is nonetheless a powerful observer, and the tool results are the leak. The companion threat model [18] develops that adversary; this paper quantifies it.

Korean regulatory context. We defer the detail to Appendix A, but one point belongs here because it shapes the whole argument. Korea's Personal Information Protection Act, including its pseudonymization provisions and its prohibition on re-identification, protects information about *natural persons*. Records about corporations are generally outside its scope. The consequence is not that corporate re-identification is harmless but that the legal shorthand "we pseudonymized it" carries no safe harbour here at all. For corporate ledgers there is no statutory standard to point at, and a vendor has nothing to offer a buyer except a measured exposure figure. That is the artefact this paper is trying to supply.

3 Setting

3.1 The gateway

A data owner holds a ledger D of n accounts. Each account i carries descriptive attributes a_i and a private quantity x_i—in our experiments a period transaction total. A hosted model plans and issues tool calls; a gateway resolves them. For each session the gateway returns a set of rows, one per matching account, and optionally an aggregate over them.

Three configuration choices define a deployment, and they are the paper's independent variables. They are not equally visible: the first is what a datasheet advertises, the second is what nobody writes down, and the third is what an analyst negotiates.

Tokenization. Each identifier is replaced by $\tau_i = F_\kappa(i)$ under a key the model never sees. The token is stable over an *epoch* of E sessions, so $E = \infty$ gives a permanently stable token and $E = 1$ a session-scoped one. Everything a gateway can offer here lies between those two, and the epoch length is the only dial: the function F_κ itself is irrelevant to every attack in this paper, because no attack we run attempts to invert it.

Disclosure profile. The set P of attribute columns returned in plaintext beside the token, each at a chosen level of a generalization hierarchy. A profile is not a security parameter in anyone's datasheet; it is usually settled during integration, by whichever columns the first dashboard needed. Section 6.5 shows it is nonetheless the variable that decides the outcome, which is why we treat it as a first-class configuration choice rather than an implementation detail.

Aggregate policy. Four separate decisions travel under this one name, and the paper separates them because they fail differently: whether $\sum_{i \in S} x_i$ is returned exactly, with additive noise, or suppressed; the minimum $|S|$ below which no answer is returned; whether a repeated query is answered from a deterministic cache or re-randomized; and what predicates may define S in the first place. The last of these turns out to matter more than the other three combined, and it is the only one that is not a database setting at all but a property of the tool schema the model is given.

3.2 Adversaries and leakage components

We use the taxonomy of the companion threat model [18] without re-deriving it. Three adversaries matter here.

$\mathcal{A}_{\text{host}}$ is the model host. It observes every prompt, tool-call argument and tool result, and can correlate across sessions. It is not assumed malicious; it is assumed to remember. Critically, $\mathcal{A}_{\text{host}}$ is also the *query planner*, so it can steer what it will later observe.

$\mathcal{A}_{\text{user}}$ is a caller with legitimate tool permissions who issues aggregate queries in order to recover individual values.

$\mathcal{A}_{\text{infra}}$ observes ciphertext at rest, access patterns and timing, and holds no key. We do not attack $\mathcal{A}_{\text{infra}}$ in this paper.

The gateway's leakage against $\mathcal{A}_{\text{host}}$ decomposes into four components, and the decomposition is drawn where it is because each component is produced by a different part of the system and mitigated by a different control. $\mathcal{L}_{\text{schema}}$ is the disclosed plaintext columns together with the filter predicates carried on tool calls; it constrains each row's identity within a public directory, and it is governed by the disclosure profile and the generalization level. $\mathcal{L}_{\text{token}}$ is the cross-session token co-occurrence graph, which exists only because tokens are stable and is therefore governed by the epoch length. $\mathcal{L}_{\text{agg}}$ is the aggregate values released, governed by the aggregate policy. $\mathcal{L}_{\text{pattern}}$ is access pattern, query frequency and timing, which no configuration choice in Section 3 removes, because it is a property of the workload rather than of the response.

The companion paper's central claim is that these do not compose additively: the adversary's advantage on the union of the components exceeds the sum of its advantages on each. Section 6 is the measurement of that claim, and Section 9 is the accounting scheme it forces.

3.3 The public directory

Every attack in this paper assumes the adversary holds a directory U of publicly enumerable firms with their published attributes and their published revenue. This is not a modelling convenience. Korea's electronic disclosure system hosts periodic reports for listed companies (order 10^3) and for companies subject to statutory external audit (order 10^4), each carrying

industry, address, revenue, headcount and founding year; the corporate registry adds the rest; and the national open-data portal publishes public-procurement contract records naming the buying institution, the item class and the winning supplier. We take $|U| = 40{,}000$.

4 Corpus

Real customer ledgers cannot be used for this study, so the corpus is synthetic. We state precisely what is calibrated to published statistics and what is invented, because the difference determines which of our results transfer.

4.1 Why corporations are not persons

The starting point is an arithmetic observation rather than an experimental one. The Korean Standard Industrial Classification, eleventh revision, has 1,196 five-digit subclasses beneath 495 four-digit classes, 232 three-digit groups, 77 two-digit divisions and 21 sections. Korean addresses are keyed to 229 si/gun/gu codes—226 basic local governments plus the two administrative cities of Jeju and the single unit of Sejong.

Industry crossed with locality therefore has $1{,}196 \times 229 = 273{,}884$ cells. The population that must hide inside them is on the order of 4×10^4 publicly enumerable corporations. The cells outnumber the firms by roughly seven to one, so most occupied cells hold exactly one firm. In our corpus, 21,883 cells are occupied, 75.3% of them by a single firm, and 41.2% of all firms sit alone in their cell. Adding the revenue band raises the singleton share to 87.7% of occupied cells and 69.6% of firms.

Nothing about tokenization changes this. It is a property of the coordinate system the state chose for describing businesses, and it holds before any gateway is deployed.

4.2 Construction

Calibrated marginals. Level cardinalities of the industry hierarchy and the count of administrative localities are the published values above. Regional concentration follows the observed concentration of Korean corporations in the capital area (roughly half). Industry popularity is heavy-tailed. Firm revenue is log-normal, headcount is correlated with revenue, and listing status is a monotone function of size. What is *not* calibrated is any joint distribution, because none is published at this resolution; the joint structure of the corpus is generated, and Section 4.4 says what follows from that.

Ledger. The vendor's book is 4,000 accounts drawn from U with a bias toward larger, audited, capital-area firms, which is how a Korean B2B vendor's customer list is actually composed.

Public relationship graph. Firms co-occur publicly when they appear against the same procuring institution or the same item class, after the national procurement feed. Participation rises with firm size. This yields 383,759 public edges over U, of which 5,545 fall inside the ledger.

Private quantity. Each account carries an amount with $\log(\text{amount}) = 0.95 \log(\text{revenue}) + \mathcal{N}(0, 0.35)$. The coefficient matters: it says an adversary holding the public revenue filing can predict the private amount up to a known log-scale error, which is what makes a recovered aggregate an identification primitive in Section 6 rather than merely a value disclosure.

4.3 Workload

The workload is 1,600 analyst sessions over six templates: single-account lookups, receivables reviews, industry rollups, regional rollups, supply-chain traces and churn watchlists. Account popularity is Zipf-distributed, so a minority of key accounts dominates, as in any real book of business. Rollups are defined by their filter predicate, so that predicate is an exact constraint on every returned row. Working-set templates draw either from a genuine commercial cluster—one that also leaves a trace in public contract records—or from a generic industry or region cohort.

The one parameter we cannot estimate. Let ρ be the probability that a working-set session is a genuine commercial cluster rather than a generic cohort. ρ governs how much of the public relationship graph is echoed into the token co-occurrence graph, and it cannot be estimated without real query logs. We therefore report the attack as a curve over $\rho \in [0, 1]$ (Section 6.6). Every headline figure in this paper is quoted at $\rho = 0.60$; the sweep shows it varies only between 9.1% and 10.0% of the ledger across the whole range, so the choice of operating point changes no conclusion.

4.4 Provenance: measured, calibrated, invented

A synthetic corpus invites a reasonable suspicion: that the results were chosen rather than found. We therefore classify every class of number in this paper into one of five provenances, exhaustively, in Table 1. The distinction is not presentational. It decides which of our results transfer to a real deployment unchanged, which will move and in which direction, and which must simply be re-measured on site.

Published. Values taken verbatim from official statistics: the 1,196 / 495 / 232 / 77 / 21 level cardinalities of the industry classification, and the 229 si/gun/gu codes. These enter the paper as constants. Nothing is fitted to them and nothing about them is ours.

Calibrated. Distributional *shapes* chosen so that the corpus's marginals reproduce published aggregates—capital-area concentration, the heavy tail of industry membership, log-normal revenue with headcount and listing status coupled to it. Only marginals are calibrated. The joint distribution is generated, which is the single most consequential modelling choice in the paper and the one we revisit in Section 10.

Invented. Everything individual: which firms exist, which of them the vendor sells to, what each account transacts, which firms meet in public contract records, and what an analyst asks on a given day. No real customer data, and no real firm, appears anywhere in this work.

Table 1: Provenance of every class of number in this paper. "Computed" means the value is an output of the released code, reproducible byte for byte under the recorded seeds; it does not mean the value was measured on real customer data, which no line of this work uses.

quantity	provenance	where
industry level cardinalities	published	Section 4
si/gun/gu count	published	Section 4
directory scale $\|U\| \sim 4 \times 10^4$	published (order)	Section 3
capital-area concentration	calibrated	Section 4
industry and size tails	calibrated	Section 4
revenue / headcount / listing coupling	calibrated	Section 4
firm identities, ledger membership	invented	Section 4
transaction amounts	invented	Section 4
public relationship graph	invented	Section 4
analyst workload and templates	invented	Section 4
ρ, workload cohesion	unmeasured, swept	Section 6.6
cell occupancy, uniqueness, k-anonymity	computed	Section 5
re-identification, precision, candidate sets	computed	Section 6
isolability, reconstruction, query counts	computed	Section 7
security/utility curves D1–D5	computed	Section 8
budget components, ε prices, modes	computed	Section 9

Computed. Every result. The re-identification rates, precisions and candidate-set sizes; the count of amounts a peeling adversary recovers; the isolability fractions; the reconstruction threshold; the query counts for the averaging attack; the five security/utility curves; the budget components and the ε prices. These are outputs of the released code run against the corpus above, not estimates and not illustrative figures. They are deterministic: re-running the pipeline from a clean checkout reproduces all five result files byte for byte, and the released `verify_claims.py` prints each of the 65 headline numbers in this paper beside the result-file field that produced it.

Unmeasured. Exactly one quantity, ρ, for the reason given above. It is reported as a sweep and never as a point value.

5 Attribute-combination re-identification

We first measure the $\mathcal{L}_{\text{schema}}$ marginal on its own: given t attributes readable from public sources, what fraction of ledger rows is uniquely determined within U? Throughout this section the denominator is the 4,000 ledger rows and the population searched is the 40,000-firm directory, so "41.4% unique" means that 41.4% of the vendor's accounts have no twin anywhere in U.

Figure 1 gives the answer over all $\binom{7}{t}$ subsets of industry, locality, revenue band, headcount band, founding year, listing status and main bank. The most informative subset reaches 41.4% at $t = 2$ (industry and locality), 74.5% at $t = 3$, 91.5% at $t = 4$ and 99.4% at $t = 6$. The median subset lags badly at small t—0.3% at $t = 2$—which matters, because it says the exposure is

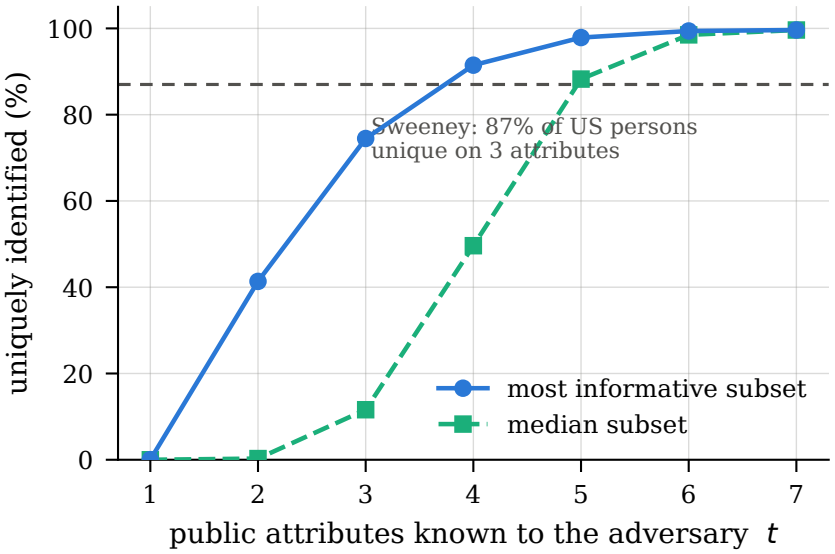


Figure 1: Fraction of ledger accounts uniquely determined inside the 40,000-firm public directory, against the number of public attributes the adversary holds. Two attributes suffice for 41.4%, four for 91.5%. The reference line is Sweeney's result for US persons; the relevant difference is not the height of the curve but that every attribute here is published by statute.

not a property of "how many columns" but of *which* columns. Industry and locality together are worth more than any four other attributes combined.

Comparison to the person case. Sweeney found 87% of the US population unique on three attributes [24]. Our corporate figure at three attributes is 74.5%—slightly lower. The comparison that matters is not the height. It is that ZIP code, date of birth and sex are not published in a searchable national archive keyed to the individual, whereas industry code, registered address, revenue band and founding year are filed, indexed and downloadable. The corporate adversary is spared the step that makes person re-identification operationally hard.

Generalization. Figure 2 traces a six-rung ladder that coarsens all attributes together. Uniqueness within U falls from 99.6% at the finest level to 3.1% at the coarsest, while the number of groups an analyst can still address falls from 3,999 to 1,171. Uniqueness *within the ledger*—which Section 7 shows is the condition for differential isolation—falls more slowly, from 99.9% to 16.0%, because the ledger is a biased sample and its rows are more distinctive relative to each other than relative to the whole directory.

6 Token linkage and composition

6.1 The adversary

$\mathcal{A}_{\text{host}}$ observes N sessions. For each it sees the tokens returned, the plaintext columns permitted by the disclosure profile, the filter predicate, and the aggregate. It proceeds in three stages.

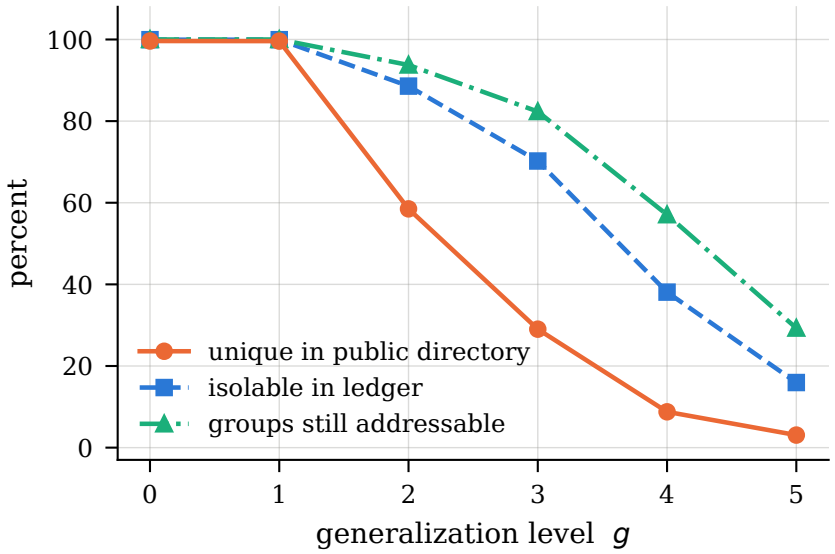


Figure 2: The generalization ladder. Coarsening buys a steep fall in uniqueness but gives up addressable groups roughly linearly. Uniqueness within the ledger decays more slowly than uniqueness within the public directory, and it is the former that governs the isolation attack of Section 7.

Stage 1: candidate narrowing ($\mathcal{L}_{\text{schema}}$). For each token, intersect the public directory on the disclosed columns and on any exact filter constraint. This yields a candidate set $C(\tau)$. Under the typical profile of Section 6.5 the median $|C(\tau)|$ is 8; under the richest profile it is 1.

Stage 2: aggregate inversion ($\mathcal{L}_{\text{agg}}$). Recover individual amounts from exact aggregates by peeling. A session with exactly one unsolved member discloses that member's amount; two sessions $S_1 \subset S_2$ with $|S_2 \setminus S_1| = 1$ disclose the extra member's. Iterating to a fixpoint over 1,600 sessions recovers 210 amounts exactly—to machine precision, not approximately. Each recovered amount is then a continuous quasi-identifier: inverting the revenue relation narrows U to the firms whose filed revenue is consistent with it. This is a linear-time adversary and therefore a lower bound; a full rank computation recovers at least as much.

Stage 3: propagation ($\mathcal{L}_{\text{token}}$). Tokens whose candidate set is now a singleton become seeds—no prior knowledge of any customer is required, because Section 5 supplies the anchors. A seeded propagation in the style of Narayanan and Shmatikov [20] then extends the mapping through the token co-occurrence graph against the public relationship graph, with three acceptance conditions: the winning candidate must be publicly adjacent to at least m distinct images of the token's already-mapped neighbours; the eccentricity of its score must clear a threshold; and the token must be the strongest proposer for that candidate within the round.

6.2 Leakage does not compose additively

Figure 3 gives the full ablation at $N = 1{,}600$ sessions under the typical disclosure profile.

The components alone. $\mathcal{L}_{\text{schema}}$ on its own re-identifies 7.3% of the ledger at precision 1.000. These are exactly the rows whose disclosed attribute vector is a singleton in the public

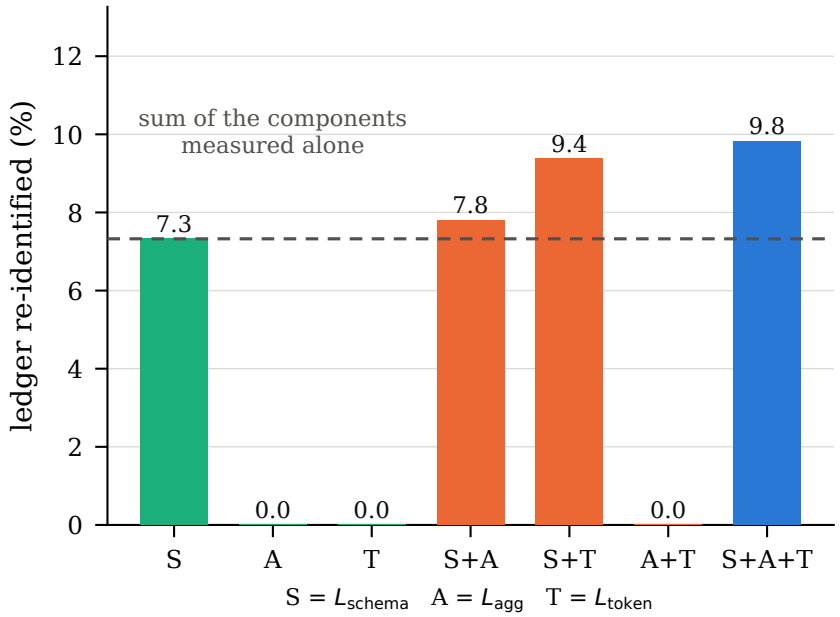


Figure 3: Re-identification under every non-empty combination of the three leakage components, at corroboration $m = 2$. The marginals sum to 7.3%; the joint reaches 9.8%. The components are not independent channels that add, and a budget that prices them separately will understate the exposure.

directory, so the attack is not really an attack: it is a lookup, and it cannot be wrong. $\mathcal{L}_{\text{agg}}$ on its own re-identifies nobody. A recovered amount narrows the universe to a median of roughly 11,500 firms, because a continuous quasi-identifier observed through a log-scale error term is informative without being close to identifying. $\mathcal{L}_{\text{token}}$ on its own also re-identifies nobody, and it fails even when we hand it 25 externally known mappings as bootstrap seeds. The reason is graph density rather than algorithm choice: a ledger of 4,000 accounts contributes 5,545 edges to a 40,000-node public graph, which is too sparse a signature for propagation to find its footing without anchors. Two of the three components are therefore worthless in isolation, which is precisely why a component-by-component budget would price them at zero.

The components in pairs. $\mathcal{L}_{\text{schema}}$ with $\mathcal{L}_{\text{agg}}$ reaches 7.8%. Aggregate inversion turns 20 further rows into directory singletons, 19 of them correctly; the recovered amount does not identify anyone by itself, but it splits candidate sets that the disclosed columns had left ambiguous. $\mathcal{L}_{\text{schema}}$ with $\mathcal{L}_{\text{token}}$ reaches 9.4%, a larger gain, and for a different reason: the singletons from $\mathcal{L}_{\text{schema}}$ are the anchors the graph attack was missing, and once it has them it extends the mapping to rows that are not distinctive at all. $\mathcal{L}_{\text{agg}}$ with $\mathcal{L}_{\text{token}}$, the pair that excludes the disclosed columns, still re-identifies nobody—two components that each need an anchor cannot supply one to each other.

Why the joint exceeds the sum. All three together reach 9.8% at precision 0.634. The sum of the three marginals is 7.3%, so the joint is a 34% relative increase over both the best marginal and the sum—an increase that exists only because two of the three marginals are zero and the third is doing work it could not do alone. Put the other way round: two components

that re-identify nobody whatsoever in isolation account for a quarter of the final result, 100 of 393 accounts, and the co-occurrence graph alone for a fifth of it. The asymmetry has a direction worth naming. $\mathcal{L}_{\text{schema}}$ is generative—it produces anchors from nothing—while $\mathcal{L}_{\text{agg}}$ and $\mathcal{L}_{\text{token}}$ are amplifying, and an amplifier with no input is silent. That is the concrete form of the composition problem the companion paper predicted, and it is why a disclosure budget cannot be assembled by pricing components in isolation: the price of a component depends on which other components are already being paid for.

6.3 Corroboration and precision

An adversary that asserts many wrong matches has not re-identified anything. We therefore separate recall from confidence by varying the corroboration requirement m:

corroboration	accounts	% of ledger	precision
$m \geq 1$	731	18.3%	0.320
$m \geq 2$	393	9.8%	0.634
$m \geq 3$	316	7.9%	0.969

Ranking asserted matches by corroboration and taking the confident head, the adversary obtains 319 matches at precision 0.911—8.0% of the ledger with near-certainty. The two operating points serve different adversaries, and both are realistic. A competitor assembling a target list acts on the $m \geq 1$ result: 731 correct identifications inside 2,285 assertions is commercially useful even though two thirds are wrong. An adversary that must be right about a specific named firm takes the $m \geq 3$ result.

We note the honest limitation: most of what the co-occurrence graph adds is low-confidence. At $m \geq 3$ the graph adds only 23 accounts over the 293 that $\mathcal{L}_{\text{schema}}$ already pins. The token graph multiplies bulk re-identification by 2.5 and barely moves confident re-identification.

6.4 Exposure is concentrated on the accounts that matter

Re-identification is not uniform over the ledger. Binning accounts by how often the workload queries them, the re-identification rate rises monotonically from 1.6% in the least-queried decile to 32.6% in the most-queried decile—a twentyfold gradient. The accounts an enterprise queries most are its largest and most strategically sensitive, and they are the ones the attack finds. The mechanism is mundane: frequently queried accounts appear in more sessions, so they accumulate more constraints and more graph evidence.

This also bounds what $\mathcal{L}_{\text{pattern}}$ contributes on its own. The mutual information between an account's query frequency and its size band is 0.009 bits against an attribute entropy of 2.85 bits—0.3%. The access pattern does not by itself disclose attributes. It determines *which* accounts the other components succeed against.

6.5 The disclosure profile dominates

Figure 4 holds everything fixed except which columns accompany the token. The candidate-set column is the median $|C(\tau)|$ that $\mathcal{L}_{\text{schema}}$ alone leaves, counting a row that carries no constraint at all at $|U|$; under P0 most rows are in that position, which is why its median stands far above the 305 that the constrained rows alone would give:

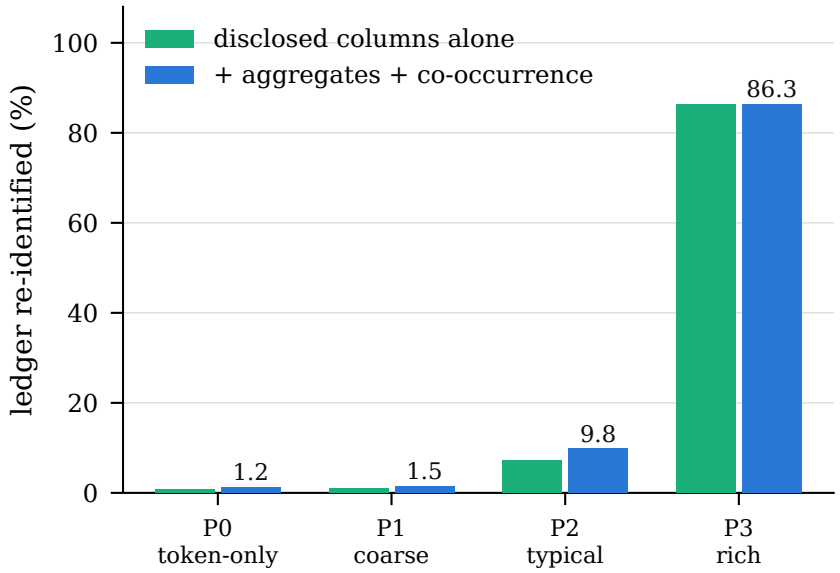


Figure 4: The same pipeline, workload and adversary under four disclosure profiles. Re-identification moves by a factor of seventy. This is the variable the gateway's operator actually controls, and the one vendors document least.

profile	columns	med. $\lvert C\rvert$	re-id
P0 token-only	—	760.0	1.2%
P1 coarse	division, region	54.0	1.5%
P2 typical	group, province, band	8.0	9.8%
P3 rich	full attribute row	1.0	86.3%

Under P3—which is simply what an analyst asks for when nobody says no—86.3% of the ledger is re-identified at precision 0.999, and 97.7% of observed rows are directory singletons before any graph reasoning happens. At that point the token is decorative: it hides the name and nothing else.

This is the answer to the procurement officer's question. A tokenizing gateway is meaningfully different from pseudonymization only if it also controls the attribute columns. Tokenization with a rich payload *is* pseudonymization, with the same exposure and an additional implication of safety.

6.6 Observation grows exposure; re-randomization barely shrinks it

Figure 5 shows exposure accumulating with observation. At 25 sessions the adversary holds 20 accounts and 3 exact amounts; at 3,200 it holds 581 accounts and 375 exact amounts. Exposure is a function of how long the deployment runs, which means a privacy claim stated at deployment time expires.

Across $\rho \in [0, 1]$, total re-identification stays within 10.1–11.2% of observed accounts at corroboration $m = 2$, while the $\mathcal{L}_{\text{schema}}$-only component stays at 8.4–8.8%. The workload-structure parameter we could not estimate turns out not to matter much. We report this as the negative result it is: it redirects attention to the disclosure profile, which does.

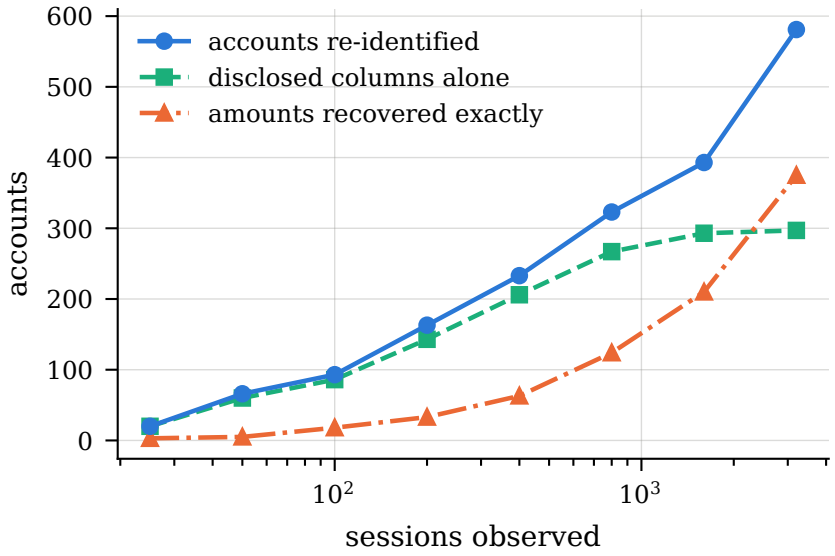


Figure 5: Exposure against sessions observed, under the typical profile. Absolute exposure grows monotonically: 20 accounts at 25 sessions, 581 at 3,200. Exactly recovered amounts grow in step.

7 Differential inference

We now turn from $\mathcal{A}_{\text{host}}$ to $\mathcal{A}_{\text{user}}$: a caller with legitimate permissions who wants one account's number.

7.1 Isolation, and why k does not help

Suppose the gateway refuses any aggregate over fewer than k rows. This is the control we most often find in deployed gateways, and it is the control the statistical-database literature discarded in the 1970s [9].

Let the caller be able to express set difference—by an exclusion clause, by an explicit identifier list, or simply by subtracting the results of two filters. Then to isolate account i it suffices to find any admissible $S \ni i$ with $|S| \geq k+1$ and take $S' = S \setminus \{i\}$, which is admissible whenever some predicate distinguishes i from the rest of S. That condition is exactly *uniqueness of i within the ledger under the filter language*—the quantity Section 5 already measured. It does not involve k.

Figure 6 confirms this experimentally: at generalization level $g = 3$, isolability is 70.2% at $k = 1$ and 70.2% at $k = 100$. At the finest level it is 99.9% at every k tested. The minimum aggregate size costs the caller nothing but padding.

Restricting the predicate language is a different matter. If only conjunctions are admissible and no exclusion clause exists, the caller must find two admissible conjunctions whose member sets differ in exactly one row, both of size $\geq k$. Isolability then falls to 39.7% at $k = 1$, 0.3% at $k = 5$ and 0.05% at $k = 10$. The two controls are not substitutes: k alone does nothing, language restriction alone leaves 39.7% exposed, and only their combination works.

Remark 1. This is a tool-schema requirement, not a database setting. It says the gateway must not expose a tool whose arguments can express "these accounts except that one," however

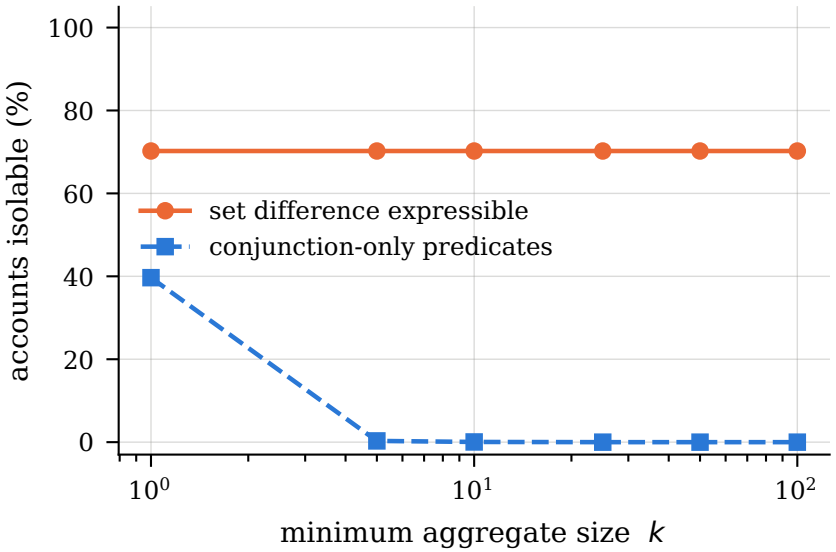


Figure 6: Fraction of accounts isolable in two queries, against the minimum aggregate size k. When the filter language can express set difference, isolability is exactly ledger uniqueness and is flat in k. Restricting the language to conjunctions collapses it—but only in combination with k.

convenient such a tool is for the model. The companion paper's tool-schema constraint list is the operational form of this requirement.

7.2 Bulk reconstruction

A caller who wants the whole vector rather than one entry issues q aggregates over random admissible sets and solves the system, after Dinur and Nissim [10]. Figure 7 shows the classical picture holds here. With exact answers the transition is sharp: below $q = n$ no coordinate is individually determined, and at $q = n$ every one is, to machine precision. Noise blunts but does not remove the threat—at σ equal to the mean account and $q = 2n$, 41.8% of accounts are recovered within 5%, and at $\sigma = 0.05$ the figure is 94.9%.

The targeted attack of the previous subsection costs two queries and the bulk attack costs n; in a deployment with thousands of accounts, the targeted attack is the one that matters, and it is the one k fails to stop.

7.3 Noise is averaged away unless answers are cached

Additive noise drawn fresh on every call is not a defence against a caller who can repeat a query. The error of the mean of $q/2$ repetitions falls as $1/\sqrt{q}$, so the caller reaches any target accuracy by paying for it. We measure the price: to bring a target within 5% relative error takes a median of 6 queries at $\sigma = 0.05$, 10 at $\sigma = 0.1$, 32 at $\sigma = 0.5$ and 42 at $\sigma = 1.0$, taking the median over 400 targets. Success is essentially universal—at or above 99.75%—at every noise level tested, and exactly universal up to $\sigma = 1.0$.

Deriving the noise deterministically from a canonical form of the query set—so that an identical query returns an identical answer—removes the repetition channel. Success then falls to 34.8% at $\sigma = 0.05$, 4.8% at $\sigma = 0.5$ and 2.8% at $\sigma = 1.0$, and the caller must instead find

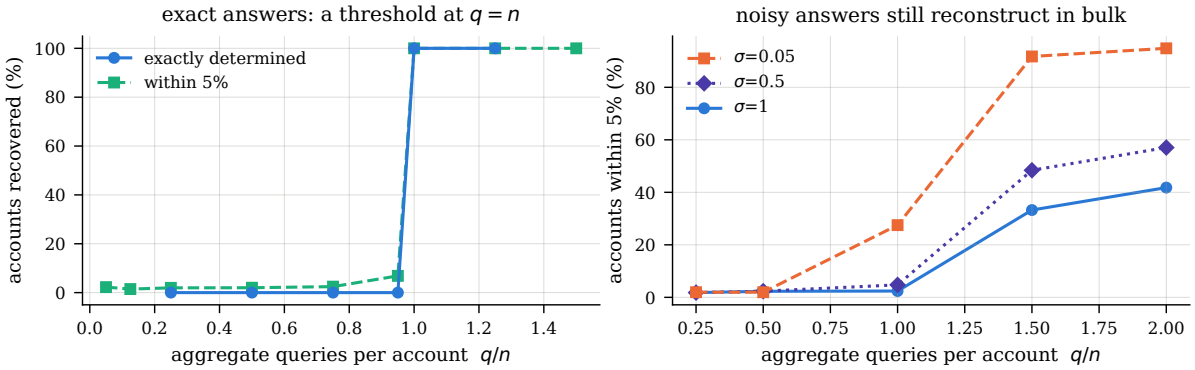


Figure 7: Left: with exact answers over random admissible sets, individual accounts are determined by a sharp threshold at $q = n$—no coordinate is individually determined below it, all are at it. Right: noise does not remove the bulk threat. At σ equal to the mean account and $q = 2n$, 41.8% of accounts are still recovered within 5%.

distinct admissible query sets, which the predicate restriction of Section 7 already limits.

Remark 2. A deterministic answer cache is cheap to implement and is, on this evidence, the single highest-leverage control in the aggregate channel. It is also the one most often omitted, because noise is usually added at the point of response generation rather than keyed to the query.

7.4 Budgets bind the analyst before the adversary

A per-principal query budget B bounds the accuracy an averaging caller can reach. At $\sigma = 0.5$, the median relative error achievable is 111.6% at $B = 2$, 26.3% at $B = 50$, 4.8% at $B = 1{,}000$ and 1.1% at $B = 20{,}000$. To hold the adversary above 5% error the budget must sit below about a thousand queries—but the legitimate workload in our corpus is 1,600 sessions, so a budget tight enough to bind the adversary serves only 62.5% of the analysts. Query budgets are a real control and a blunt one: they do not distinguish an adversary from a busy analyst, because on this channel there is no behavioural difference between them.

8 Defences and what they cost

Figure 8 puts each defence on a frontier with its security measure on the horizontal axis and its utility measure on the vertical.

D1, epoch-scoped tokens: the control that does not work. Shortening the token epoch from permanent to a single session reduces re-identification from 9.8% to 7.9% of the ledger (316 accounts at precision 0.948; the numerical coincidence with the $m \geq 3$ row of Section 6 is accidental). It removes 100% of cross-session account linkage—every trend, every churn signal, every "how is this customer doing versus last quarter." The frontier is almost vertical. The reason is now obvious: re-identification is driven by $\mathcal{L}_{\text{schema}}$, which re-accumulates within every epoch no matter how often tokens are rotated. Rotating tokens protects against an adversary

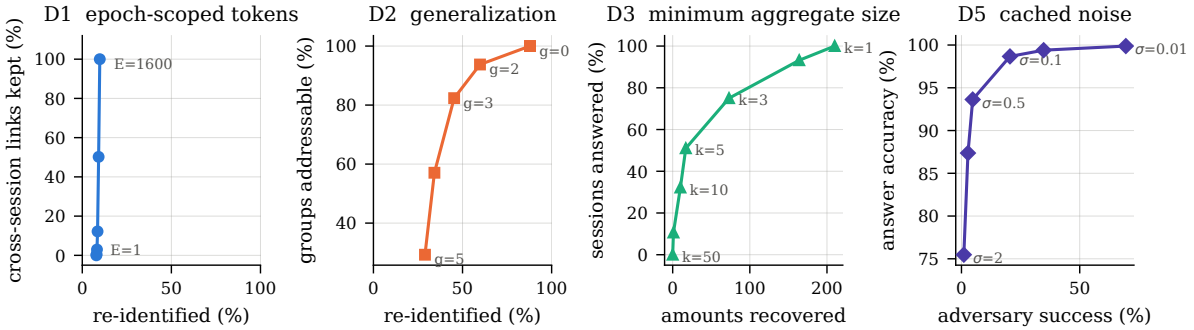


Figure 8: Security/utility frontiers, measured on the same runs. Each point is a parameter setting; down and left is worse. D1 is nearly vertical: epoch-scoped tokens surrender the entire cross-session workload for a two-point reduction in re-identification. D2 and D5 have usable knees; D3 does not.

whose only channel is the co-occurrence graph, and Figure 3 shows that adversary re-identifies nobody anyway.

This is worth stating bluntly because session-scoped tokenization is a frequently advertised feature. On this evidence it is the worst security-per-unit-utility control of the five.

D2, generalization: the effective lever. Moving down the ladder takes re-identification from 87.9% to 28.9% while retaining 29.3% of addressable groups; the knee sits around $g = 3$–4, where re-identification is 45.3%–34.2% and 82.3%–57.1% of groups survive. Because $\mathcal{L}_{\text{schema}}$ dominates, this is where the operator's effort belongs.

D3, minimum aggregate size: expensive and, alone, ineffective. Raising k from 1 to 5 cuts peeled amounts from 210 to 17 but answers only 51.0% of the workload; $k = 25$ leaves 1 amount and answers 10.6%. And per Section 7 it does not touch targeted isolation at all. k is worth having as a companion to predicate restriction and worth nothing as a standalone control.

D4, query budget. As measured above: binds the analyst at roughly the same point it binds the adversary.

D5, cached noise: the best aggregate-channel control. At $\sigma = 0.5$ the analyst's median relative error is 6.4% overall—but 19.4% on aggregates over five rows or fewer—while the cached adversary succeeds 4.8% of the time. The asymmetry exists because the analyst asks about large sets and the adversary asks about small ones. That asymmetry, not the noise magnitude, is what makes the control work, and it argues for scaling noise to set size rather than applying it uniformly.

9 The disclosure budget

9.1 Components

Definition 1 (Disclosure budget)**.** For a gateway configuration Π and a workload W, the disclosure budget is the tuple

$$\mathcal{B}(\Pi, W) = \big(\beta_{\text{schema}},\ \beta_{\text{token}},\ \beta_{\text{agg}},\ \beta_{\text{pattern}}\big)$$

whose components are defined as follows.

β_{schema} is the identity information the disclosed columns release per row, in bits: $\log_2 |U| - \mathbb{E}\big[\log_2 |C(\tau)|\big]$. Out of the 15.29 bits needed to name a firm in U, the token-only profile releases 6.74, the typical profile 12.20 and the rich profile 15.26.

β_{token} is the re-identification the co-occurrence graph adds on top of β_{schema}, in points of the ledger. It is 2.1 points under the typical profile and below half a point under the rich one—the graph has nothing left to contribute once the columns have done the work.

β_{pattern} is the mutual information between the observable access pattern and a private attribute: 0.009 bits of 2.85, or 0.3%.

β_{agg} is where the accounting breaks, and that is the point.

9.2 Exact aggregates admit no ε

Claim 1. *Let the gateway answer* SUM *queries exactly over caller-chosen admissible sets. If the admissible family contains two sets S, S' with $S \setminus S' = \{i\}$ for some record i, then the aggregate channel satisfies ε-differential privacy for no finite ε.*

Proof. Let D, D' be neighbouring databases differing only in record i, with $x_i \neq x'_i$. The release $(q_S, q_{S'})$ is deterministic and $q_S - q_{S'}$ equals x_i on D and x'_i on D'. The two output distributions are point masses at distinct points; their supports are disjoint, so no finite ε bounds the ratio required by the definition. □

Corollary 2. *A minimum aggregate size k does not restore a guarantee. By Section 7, whenever record i is distinguishable from every other record by the filter language, such a pair S, S' exists with both sets of size at least k, and obtaining it costs two queries.*

The claim is elementary. We state it formally because the product conversation it settles is not. A vendor offering an "exact analytics mode" alongside a "private mode" is not offering two points on a privacy-utility curve. The exact mode is off the curve: it has no privacy parameter at all, and its exposure can only be stated combinatorially—which rows are isolable, how many amounts a peeling adversary recovers, how many accounts are re-identified. Those are the numbers Table 2 reports for it.

9.3 What randomization costs on a heavy tail

Suppose the vendor takes the corollary seriously and randomizes. A SUM query over an unbounded quantity has no finite sensitivity, so contributions must first be clipped. Clipping at the 99th percentile of our amount distribution loses 6.9% of total volume—already a real

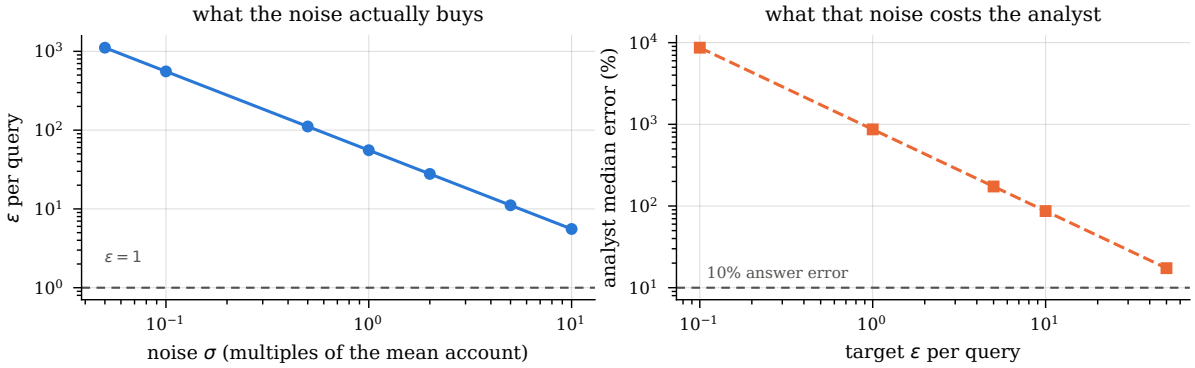


Figure 9: Left: the ε per query actually delivered by a given noise level, for a clipped SUM query at $\delta = 10^{-6}$. Right: the analyst's median answer error implied by a target ε. The two panels share no axis; the gap between them is the finding.

Table 2: Four gateway configurations against their measured disclosure budgets, at $N = 1{,}600$ sessions. "Isolable" is the fraction of accounts a caller can pin in two queries; "amounts" is what a peeling adversary recovers exactly; "answered" is the fraction of the legitimate workload that still returns an aggregate. Mode A is what ships when nobody decides. Mode D is the only row with a defensible story, and it answers a third of the workload.

mode	profile / tokens	aggregate policy	β_{schema} (bits)	re-id (%)	isolable (%)	amounts recovered	answered (%)	formal guarantee
A. Exact analytics	rich / stable	exact, any predicate	15.26	86.3	99.9	210	100.0	none (Claim 1)
B. Constrained exact	typical / stable	exact, conj. only, k=5	12.20	9.4	0.3	17	51.0	none (Claim 1)
C. Randomised ad hoc	typical / stable	cached noise σ=0.5, k=5	12.20	9.4	0.3	0	51.0	$\varepsilon = 111$/query
D. Split channel	coarse / epoch	registered exact + noisy ad hoc	9.56	1.1	0.05	10	32.2	DP, ad-hoc channel only

utility cost—and leaves a sensitivity of 10.5× the mean account, because corporate ledgers are heavy-tailed by nature.

The consequences, under the classical Gaussian mechanism at $\delta = 10^{-6}$, are stark (Figure 9). The noise level at which the analyst still sees 6.4% median error, $\sigma = 0.5$, delivers $\varepsilon = 111.2$ per query, or 1.11×10^5 over a thousand-query epoch under basic composition. Running the calculation backwards: $\varepsilon = 10$ per query demands $\sigma = 5.56\times$ the mean account and a median answer error of 87%; $\varepsilon = 1$ demands $\sigma = 55.6\times$ and a median error of 867%.

Remark 3. We are not arguing that differential privacy is inapplicable to enterprise analytics. We are reporting that *per-query sensitivity-based* accounting on unbounded, heavy-tailed corporate amounts prices at a level no analyst will accept, and that a vendor quoting an ε for this channel is either clipping far more aggressively than they disclose, or answering a different question than the one their customer is asking. The productive direction is to control the query family—which Section 7 shows is effective and cheap—rather than to buy a guarantee with noise.

9.4 Four product modes

Table 2 instantiates the budget for four configurations. Reading it as a specification decision:

Mode A is what a gateway becomes if no one makes a decision: the analyst asks for every column and exact figures, and gets them. It re-identifies 86.3% of the ledger and exposes all but two accounts in a thousand to two-query isolation. It should not be sold as a privacy product.

Mode B keeps exact figures and hardens everything around them. It is a large improvement—re-identification 9.4%, isolability 0.3%—and it still has no formal guarantee, because Claim 1 does not care how hard the predicates are to write. It answers half the workload. This is a defensible product provided the exposure figures are stated, and indefensible if it is marketed with the word "anonymous."

Mode C adds cached noise. It eliminates exact amount recovery entirely, changes re-identification not at all—because re-identification runs on $\mathcal{L}_{\text{schema}}$—and buys an ε too large to quote. Its honest selling point is the amount channel, not a DP guarantee.

Mode D splits the channel: exact figures only for a pre-registered, non-adaptive set of reports, and noisy answers for everything ad hoc. The registered family contains no two sets differing in one record by construction, so Claim 1 does not apply to it, and the ad-hoc channel can carry a genuine DP account. It re-identifies 1.1% of the ledger at precision 1.000 and answers 32.2% of the workload.

The decision this forces. A vendor must choose between Mode B and Mode D, and the choice is not technical. Mode B answers 1.6 times the workload and cannot be described with any privacy parameter. Mode D can be described, and gives up two thirds of the ad-hoc analytics that make the product attractive. There is no configuration in our measurements that is both. We recommend shipping Mode D as the default with Mode B available under an explicit, logged, contractually acknowledged setting—and never shipping Mode A.

10 Limitations

What transfers, and what has to be re-measured. The corpus is synthetic (Section 4.4), so the results do not all carry the same weight, and it is worth separating them into four tiers rather than offering a single disclaimer.

Independent of the corpus entirely. Claim 1 and its corollary are proofs, and the identity between isolability and ledger uniqueness that Section 7 establishes is an argument about the closure of a predicate family. The corpus illustrates them; it does not support them. These hold for any deployment answering exact aggregates over caller-chosen sets, whatever its data looks like.

Dependent on the coordinate system only. The cell-occupancy arithmetic of Section 4—273,884 cells against roughly 4×10^4 firms, and therefore singleton-dominated occupancy—follows from the classification the Korean state publishes and the number of corporations that exist. Any real Korean corporate ledger inherits it. The specific occupancy percentages we report will differ from a real ledger's; the qualitative conclusion cannot.

Dependent on the joint distribution. The uniqueness percentages of Section 5, and through them the re-identification and isolability percentages of Sections 6 and 7, depend on how industry, locality and size co-vary—which is exactly what we generate rather than calibrate, since it is not published at this resolution. These figures will move on real data. We expect them to move *up*: real industry-locality distributions are more spatially concentrated than our Dirichlet-generated hierarchy, and concentration in the marginals with correlation in the joint produces more singletons, not fewer. We state this as an expectation, not a result.

Dependent on the workload. The session-count curve of Section 6.6, the β_{token} component,

and the defence curves that involve epochs or budgets are all functions of how an organization actually queries. These are the least transferable numbers in the paper and the ones a deployment should re-run against its own logs; the released pipeline is structured so that replacing the generator in `corpus.py` with a real loader leaves the attacks, defences and budget code untouched.

Every attack is a lower bound. The peeling adversary is linear-time where a rank computation would recover more. The propagation uses only the public relationship graph where a stronger adversary would add temporal correlation and reverse-matching. The candidate narrowing uses exact equality where a probabilistic matcher would tolerate filing errors. We report what we measured, not what is achievable.

We did not attack $\mathcal{A}_{\text{infra}}$. Access-pattern and volume attacks on the encrypted store [16] are out of scope here and are the subject of separate work.

The model host is assumed honest-but-curious. An actively malicious host that steers the analyst toward chosen queries is strictly stronger; the companion paper identifies it as the setting for the admission-control work that follows this paper.

ρ is unmeasured. We report the curve. If a deployment's workload is far more cluster-structured than anything we simulated, the $\mathcal{L}_{\text{token}}$ contribution rises; our sweep suggests the effect is small relative to the disclosure profile. It is the one place in the paper where we could not close the gap between what we could compute and what we would need to know.

11 Conclusion

Tokenizing a corporate identifier is a weaker control than it appears, and the reason is not cryptographic. It is that the Korean state publishes a high-resolution coordinate system for businesses, that the coordinate system has more cells than there are businesses, and that the gateway typically hands the model enough coordinates to locate the row it just tokenized.

The measurements say three things a gateway operator can act on. First, the disclosure profile dominates everything else: 1.2% versus 86.3% re-identification, on the same pipeline, from the choice of which columns accompany the token. Second, the controls most often advertised are the ones that work least—session-scoped tokens surrender all cross-session analysis for two points of re-identification, and minimum aggregate sizes do not prevent isolation at any k—while the controls that work are unglamorous: coarsen the columns, forbid set difference in the tool schema, cache the noise. Third, an exact-aggregate mode has no privacy parameter, and saying so in the datasheet is the only honest option available.

The last point is the one we expect to be resisted, because exact figures are what enterprise analytics customers ask for first. But the alternative to stating the exposure is not avoiding it; it is shipping it undocumented, and discovering it later in an incident report.

Availability. The corpus generator, the three attacks, the defence evaluation, the budget computation, all result files, the figure scripts and a provenance checker are released with fixed

seeds. Every number in this paper is an output of that code (Section 4.4); none is an estimate, and the checker prints each of the 65 headline figures beside the result-file field it came from.

References

[1] Nabil R. Adam and John C. Worthmann. Security-control methods for statistical databases: A comparative study. *ACM Computing Surveys*, 21(4), 1989.

[2] Nicholas Carlini, Florian Tramer, Eric Wallace, Matthew Jagielski, Ariel Herbert-Voss, Katherine Lee, Adam Roberts, Tom Brown, Dawn Song, Ulfar Erlingsson, Alina Oprea, and Colin Raffel. Extracting training data from large language models. In *USENIX Security Symposium*, 2021.

[3] David Cash, Paul Grubbs, Jason Perry, and Thomas Ristenpart. Leakage-abuse attacks against searchable encryption. In *ACM Conference on Computer and Communications Security (CCS)*, 2015.

[4] Melissa Chase and Seny Kamara. Structured encryption and controlled disclosure. In *Advances in Cryptology – ASIACRYPT*, 2010.

[5] Reza Curtmola, Juan Garay, Seny Kamara, and Rafail Ostrovsky. Searchable symmetric encryption: Improved definitions and efficient constructions. In *ACM Conference on Computer and Communications Security (CCS)*, 2006.

[6] Yves-Alexandre de Montjoye, César A. Hidalgo, Michel Verleysen, and Vincent D. Blondel. Unique in the crowd: The privacy bounds of human mobility. *Scientific Reports*, 3, 2013.

[7] Yves-Alexandre de Montjoye, Laura Radaelli, Vivek Kumar Singh, and Alex Pentland. Unique in the shopping mall: On the reidentifiability of credit card metadata. *Science*, 347(6221), 2015.

[8] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2024.

[9] Dorothy E. Denning, Peter J. Denning, and Mayer D. Schwartz. The tracker: A threat to statistical database security. *ACM Transactions on Database Systems*, 4(1), 1979.

[10] Irit Dinur and Kobbi Nissim. Revealing information while preserving privacy. In *ACM Symposium on Principles of Database Systems (PODS)*, 2003.

[11] Cynthia Dwork, Frank McSherry, Kobbi Nissim, and Adam Smith. Calibrating noise to sensitivity in private data analysis. In *Theory of Cryptography Conference (TCC)*, 2006.

[12] Cynthia Dwork and Aaron Roth. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, 9(3–4), 2014.

[13] Simson Garfinkel, John M. Abowd, and Christian Martindale. Understanding database reconstruction attacks on public data. *Communications of the ACM*, 62(3), 2019.

[14] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *ACM Workshop on Artificial Intelligence and Security (AISec)*, 2023.

[15] Paul Grubbs, Kevin Sekniqi, Vincent Bindschaedler, Muhammad Naveed, and Thomas Ristenpart. Leakage-abuse attacks against order-revealing encryption. In *IEEE Symposium on Security and Privacy (S&P)*, 2017.

[16] Georgios Kellaris, George Kollios, Kobbi Nissim, and Adam O'Neill. Generic attacks on secure outsourced databases. In *ACM Conference on Computer and Communications Security (CCS)*, 2016.

[17] Siwon Kim, Sangdoo Yun, Hwaran Lee, Martin Gubri, Sungroh Yoon, and Seong Joon Oh. ProPILE: Probing privacy leakage in large language models. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2023.

[18] Caleb Lee. Threat model and exposure boundary for tokenizing LLM gateways. Companion paper, J1729Labs, under submission, 2026.

[19] Arvind Narayanan and Vitaly Shmatikov. Robust de-anonymization of large sparse datasets. In *IEEE Symposium on Security and Privacy (S&P)*, 2008.

[20] Arvind Narayanan and Vitaly Shmatikov. De-anonymizing social networks. In *IEEE Symposium on Security and Privacy (S&P)*, 2009.

[21] Muhammad Naveed, Seny Kamara, and Charles V. Wright. Inference attacks on property-preserving encrypted databases. In *ACM Conference on Computer and Communications Security (CCS)*, 2015.

[22] Luc Rocher, Julien M. Hendrickx, and Yves-Alexandre de Montjoye. Estimating the success of re-identifications in incomplete datasets using generative models. *Nature Communications*, 10, 2019.

[23] Robin Staab, Mark Vero, Mislav Balunović, and Martin Vechev. Beyond memorization: Violating privacy via inference with large language models. In *International Conference on Learning Representations (ICLR)*, 2024.

[24] Latanya Sweeney. Simple demographics often identify people uniquely. Technical report, Carnegie Mellon University, Data Privacy Working Paper 3, 2000.

[25] Latanya Sweeney. k-anonymity: A model for protecting privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*, 10(5), 2002.

[26] Da Yu, Saurabh Naik, Arturs Backurs, Sivakanth Gopi, Huseyin A. Inan, Gautam Kamath, Janardhan Kulkarni, Yin Tat Lee, Andre Manoel, Lukas Wutschitz, Sergey Yekhanin, and Huishuai Zhang. Differentially private fine-tuning of language models. In *International Conference on Learning Representations (ICLR)*, 2022.

A Regulatory mapping

The pseudonymization vocabulary that gateway vendors use is borrowed from data protection law, and it is worth being exact about where the borrowing holds.

Korea, PIPA. The Personal Information Protection Act governs information relating to an identified or identifiable *natural person*. Its 2020 amendments created the pseudonymized-information regime, permitting processing for statistical, research and public-interest archiving purposes without consent, subject to safeguards, and separately prohibiting any attempt to re-identify pseudonymized information. Information about a corporation is not, on its own, personal information.

Two consequences follow, and they point in opposite directions. First, a gateway over a purely corporate ledger cannot claim the pseudonymized-information safe harbour, because there is no personal information to pseudonymize; the statutory vocabulary simply does not attach. Second, and more practically, real corporate ledgers are rarely purely corporate—they carry representative names, contact persons, and account managers—so the moment such a column enters the disclosure profile, the full regime attaches to it, including the re-identification prohibition. The safe reading is that the corporate columns carry no statutory protection and the incidental personal columns carry all of it.

Korea, Credit Information Act. For financial institutions the Credit Information Use and Protection Act imposes a parallel and in places stricter pseudonymization regime, including on corporate credit information, which does reach corporate records in that sector.

Korea, electronic financial supervision. The Regulation on Supervision of Electronic Financial Transactions imposes access control, logging and separation requirements on financial institutions' systems. The boundary-crossing operation of Section 3—any decryption or disclosure event—is the natural logging unit under these requirements, and every measured exposure in this paper corresponds to a sequence of such events that would be individually authorized and individually logged.

EU, GDPR. Article 32 requires security appropriate to the risk, naming pseudonymization as an example measure; Recital 26 makes clear that pseudonymized data that can be attributed to a person with additional information remains personal data. Our results are a direct, quantified instance of "additional information": the public directory is the additional information, and Section 5 measures how much of it is needed. GDPR does not apply to corporate records either, but the Recital 26 test—means reasonably likely to be used—is the right test, and it is an empirical one.

The upshot. For corporate data the vendor cannot lean on a statutory definition, because none applies. What is left is the measured exposure, which is why we think a disclosure budget of the kind in Section 9 belongs in the datasheet rather than in a research paper alone.

B Reproduction

All experiments run single-threaded on a commodity CPU. Fixed seeds are recorded in the generator—the corpus seed is 20260920, the workload seed is 7, and every sweep records its own—so the pipeline is deterministic end to end. We checked this rather than assuming it: deleting all five result files and re-running the pipeline from scratch reproduced each of them byte for byte. Wall-clock cost is dominated by the two sweeps that re-run an attack per parameter setting, the linkage ablation ($\approx$ 5.5 minutes) and the epoch sweep of defence D1 ($\approx$ 5.5 minutes, since $E = 1$ means re-running the attack 1,600 times); everything else finishes in seconds.

`verify_claims.py` is the provenance checker referred to in Section 4.4. It re-reads the result files and prints every headline number in the paper next to the JSON path that produced it, so a reader can confirm that no figure in the text was written by hand. It is the artefact we would want if we were reviewing this paper rather than writing it.

file	produces
`corpus.py`	universe, ledger, public graph, workload
`attack2_unique...`	Section 5; Figs. 1, 2
`attack1_linkage.py`	Section 6; Figs. 3, 4, 5
`attack3_inference.py`	Section 7; Figs. 6, 7
`defenses.py`	Section 8; Fig. 8
`budget.py`	Section 9; Tab. 2; Fig. 9
`figures.py`	all figures
`verify_claims.py`	65 headline numbers, traced to their source